



TRACKERX

SECURITY & RELIABILITY REMEDiation AUDIT

Production code, API, database, dependency, host, and availability assessment

AUDIT DATE	10 September 2026
PRODUCTION	trackerx.defendexe.com
ASSESSMENT	Audit with concurrent remediation
VERDICT	READY - CONTROLLED SINGLE-HOST DEPLOYMENT

Prepared for production deployment and operational handoff

01

Executive verdict

A direct statement of current production readiness and the limits of this assessment.

READY

All confirmed critical and high-risk findings discovered during this audit were remediated and re-tested. Production passed database integrity, API stability, dependency, transport, host, backup, and recovery checks.

FINDINGS CLOSED

14 / 14

Confirmed audit findings

API OPERATIONS

112

No unauthenticated 500s

AUTOMATED TESTS

50 / 50

Passed in isolated data paths

HOST HARDENING

2.8 OK

From 7.6 EXPOSED

What changed

- Seven accounts using the prior shared demo password were rotated to unique temporary credentials; existing sessions were revoked and password change is mandatory.
- SSH now accepts keys only, rejects root/password login, and limits authentication attempts. The firewall allows only SSH, HTTP, and HTTPS.
- Production refuses an unexpected or incomplete database; readiness validates schema, users, integrity, and object storage.
- A verified daily backup timer and a one-minute application readiness/recovery timer now supplement process restart controls.
- The backend systemd sandbox now has no Linux capabilities and only writes to the required data and backup directories.

IMPORTANT LIMIT

This is not a promise of absolute uptime or an independent certification. TrackerX still runs on a single host with SQLite. Host, datacenter, DNS, or upstream network failure can interrupt service; the prioritized architecture controls are listed on page 8.

02

Scope and audit method

Evidence was gathered from source, tests, the live application, host controls, and a read-only production database audit.

CONTROL	VERIFIED RESULT
Backend source	11,447 lines of Python application code; authentication, authorization, validation, file handling, exports, and error paths.
API surface	81 OpenAPI paths and 112 unique method/path operations; full unauthenticated failure sweep.
Database	SQLite schema completeness, quick check, foreign keys, account constraints, duplicates, compromised-password detection, permissions, and backup recovery.
Dependencies	Python runtime/development packages and JavaScript dependency graph checked against published advisories.
Infrastructure	TLS, headers, listening ports, SSH, firewall, systemd isolation, restart behavior, recovery, timers, disk, and memory.
Frontend	TypeScript validation, Vite production build, route-level splitting, and generated asset sizes.

Reference-document boundary

The supplied AI Tutor security and engineering audit reports were used as a checklist and presentation reference only. They concern another product. LLM, RAG, prompt-injection, and vector-store findings are not applicable because TrackerX contains none of those components.

Severity and closure standard

- Critical: practical account, data, or host compromise with material impact.
- High: strong security, integrity, or availability impact requiring release-blocking remediation.
- Medium: defense-in-depth or resilience weakness that meaningfully raises operational risk.
- Closed: code or configuration changed, the control was deployed, and relevant verification succeeded.

Audit approach

The review combined static analysis, dependency analysis, targeted source tracing, isolated automated tests, production-safe API requests, host inspection, read-only database inspection, controlled service restart checks, and verified backup creation. Secrets and password hashes were not copied into this report.

03

Findings and remediation

Every confirmed finding was fixed during the audit and re-tested against the affected control.

ID / RISK	FINDING	REMEDIATION AND VERIFIED EVIDENCE	STATUS
TX-26-01 Critical	Seven production accounts matched the shared demo password.	Created a verified pre-change backup; assigned unique random temporary passwords; incremented auth_version; required password change. Re-audit: 0 matches.	CLOSED
TX-26-02 High	SSH permitted password authentication and direct root login.	Installed key-only policy; disabled root/password/interactive login; set MaxAuthTries 3; sshd configuration and fresh key session passed.	CLOSED
TX-26-03 High	Database and backup paths had overbroad modes.	Data and backup directories are 700; database, environment, archives, and rotation file are 600.	CLOSED
TX-26-04 High	Demo/sample data commands were not production-safe.	Commands now fail closed in production; built-in demo password removed; explicit policy-compliant local value required.	CLOSED
TX-26-05 Medium	Office previews used the standard XML parser.	Moved to defusedxml and added malicious DTD/entity expansion regression coverage.	CLOSED
TX-26-06 High	Health only proved a trivial database query.	Readiness now verifies all required tables, a production user, SQLite quick_check, and object storage; startup blocks wrong/incomplete production databases.	CLOSED
TX-26-07 Medium	Backups occurred only on application startup.	Added persistent daily systemd timer, integrity/checksum verification, and retention of 14 newest archives.	CLOSED

03

Findings and remediation - continued

ID / RISK	FINDING	REMEDIATION AND VERIFIED EVIDENCE	STATUS
TX-26-08 Medium	No application-level recovery loop existed.	Added one-minute readiness timer and controlled recovery unit; failure triggers restart only after bounded retries.	CLOSED
TX-26-09 Medium	SQLite used default concurrency and relationship settings.	Enabled WAL, foreign keys, 30-second busy timeout, normal synchronous mode, connection pre-ping, and PRAGMA optimize.	CLOSED
TX-26-10 Medium	Failures lacked a stable support reference.	Added X-Request-ID; database outages return 503 with Retry-After; unexpected errors return a stable ID and retain server traceback.	CLOSED
TX-26-11 High	Test import order could select production data before isolation.	Safe runner selects disposable database/document/backup paths before imports and disposes handles afterward; CI uses it.	CLOSED
TX-26-12 Medium	Initial JavaScript bundle was 759 KB.	Route-level lazy loading reduced main bundle to 270.12 KB (90.03 KB gzip); largest route chunk 219.10 KB.	CLOSED
TX-26-13 Medium	Host firewall was inactive.	Enabled default-deny inbound firewall with only TCP 22, 80, and 443 allowed; backend/storage/database remain loopback-only.	CLOSED
TX-26-14 Medium	Health timer could race application startup.	Added bounded connection retries and proved controlled restart plus immediate probe; result is success without redundant recovery.	CLOSED

Credential remediation safeguard

The rotation output exists only on the server in an owner-readable file. This report deliberately excludes temporary credentials and password hashes. Each account holder must receive only their own credential and complete the forced password change.

04

Application and API security

Controls are assessed by outcome across authentication, authorization, injection resistance, files, and browser boundaries.

Authentication and sessions

- Bcrypt password hashing; 12-to-72-byte policy; three character classes; common, repeated, and identity-derived passwords rejected.
- Secure, HttpOnly, SameSite=Strict cookies in production; JWT issuer, audience, algorithm, expiry, issued-at, subject, token ID, and authorization version validated.
- Sensitive access changes revoke sessions. Login enumeration is limited and throttling returns 429 with Retry-After.

Authorization and portal boundaries

- Owner/admin controls, project-manager scope, employee membership, and client disclosure are enforced in reusable backend dependencies.
- Clients receive only linked projects and reports explicitly forwarded to them; profile/CV files remain private to employee and administrators.
- Project managers assign tasks only inside managed rosters; leave approval routes employees to PM/admin and PM/admin to owner.

Injection, input, and uploads

- User-controlled database values use SQLAlchemy expressions or bound parameters; no user-controlled SQL fragment or identifier was found.
- Storage keys reject absolute paths, traversal, empty segments, and backslashes. Uploads enforce size, count, extension, filename, and empty-file limits with rollback.
- Office archives cap total unpacked size at 30 MB and reject dangerous XML entities/DTDs; risky active formats render as plain text.

Transport and browser

- Caddy terminates TLS and redirects HTTP. HSTS, CSP, DENY framing, nosniff, referrer, permissions, COOP, CORP, no-store, and request-ID headers are active.
- CORS and trusted hosts are explicit. Production OpenAPI documentation returns 404. Non-public services bind only to localhost.

05

Database security and integrity

The live audit utility opened SQLite read-only and reported control outcomes without copying credentials or hashes.

CONTROL	VERIFIED RESULT
Environment	production
SQLite quick check	ok
Foreign-key violations	0
Schema	26 tables; all required application tables present
Accounts	14 total; 10 enabled; exactly 1 enabled primary owner/admin
Identity/state constraints	0 duplicate case-insensitive emails; 0 invalid role, access, or enabled states
Compromised-password matches	0 after rotation
Filesystem permissions	Data/database: 700/600; backups/archives: 700/600; environment file: 600
SQLite runtime controls	WAL; foreign keys per connection; 30-second busy timeout; connection pre-ping

SQL injection assessment

All user-controlled query values reviewed use SQLAlchemy expression binding or explicit bound parameters. Remaining direct driver and SQLite statements are fixed schema migrations, static maintenance statements, or parameterized operations. No reachable path was found where a user controls a SQL identifier, operator, ordering expression, or raw clause.

Backup assurance

- SQLite online backup prevents an inconsistent copy while writes occur.
- Every archive receives database integrity validation, SHA-256 entry checksums, and document manifest coverage.
- Verified pre-remediation, scheduled, and startup backups exist with owner-only permissions.

06

Availability and operational resilience

Layered detection and recovery now cover process failure, application readiness, reboot gaps, and routine data recovery.

CONTROL	VERIFIED RESULT
Public readiness	HTTP 200 in 0.039 seconds; status, database, schema, integrity, and storage all ok
Process liveness	/api/health/live available separately from full dependency readiness
Recovery loop	One-minute systemd timer; restart only after bounded retries fail
Backups	Persistent daily timer; startup backup; retention of 14 newest archives
Service isolation	No capabilities; strict filesystem; private devices/temp; restricted process, namespace, address-family, and system-call exposure
systemd exposure	2.8 OK after hardening, improved from 7.6 EXPOSED
Network surface	Public TCP 22/80/443 only; API, database, and object storage on loopback
Capacity snapshot	Approximately 10 GiB available memory; 186 GiB disk free; 4% disk used

Request-failure behavior

Database operational faults are classified as temporary dependency failures and return HTTP 503 plus Retry-After. Unexpected application errors return a stable request ID instead of leaking internals. The same request ID is present in server logs and the response, making production incidents traceable without exposing stack details.

SINGLE-HOST REALITY

The controls above materially reduce downtime and speed recovery, but they cannot make one server always available. Independent uptime requires redundant instances and replicated external data services.

07

Verification record

Release gates were rerun after remediation; production-only controls were validated on the live host.

CONTROL	VERIFIED RESULT
Backend tests	50 / 50 passed
API failure sweep	112 operations; no unauthenticated HTTP 500 responses
OpenAPI uniqueness	112 unique method/path operations
Ruff	Passed
Bandit	11,447 application lines; 0 low, medium, or high findings
Python dependency audit	No known vulnerabilities
npm audit	0 vulnerabilities
Python compilation	Passed
Frontend	TypeScript validation and Vite production build passed
Public controls	Readiness 200; security headers verified; production OpenAPI 404
Operational drills	Immediate verified backup, controlled restart, readiness retry, and fresh SSH key session passed

Release decision

APPROVED

Approved for the current controlled single-host production model, subject to the credential handoff and residual-risk roadmap on the next page.

08

Residual risk and prioritized roadmap

These are architecture or external-service limits, not hidden exceptions to the remediated findings.

PRIORITY	CONTROL	NEXT ACTION
P0	Credential handoff	Privately deliver each temporary password, require the first-login change, then securely delete the server rotation file.
P1	Off-server recovery	Copy encrypted backups off-host, define recovery objectives, and prove restoration through scheduled drills.
P1	Independent monitoring	Monitor the public HTTPS endpoint from outside the server and alert on sustained failure and recovery.
P1	High availability	Migrate SQLite to managed PostgreSQL, replicate object storage, and run at least two API instances behind the proxy.
P1	Privileged MFA	Add WebAuthn or TOTP for owner, admin, and project-manager accounts.
P2	Shared throttling	Move rate-limit state to Redis before horizontal scaling.
P2	Upload malware scanning	Add quarantine and antivirus scanning when files come from broadly untrusted external users.
P2	Central security telemetry	Centralize request-ID logs, retention, anomaly detection, and incident paging.

Final conclusion

All confirmed code, database, credential, permission, host-access, and availability defects identified in this audit were remediated and verified in production. TrackerX satisfies the current single-host deployment model. The roadmap above defines the next maturity step for stronger availability and assurance.

OWNER ACTION

Temporary credentials are stored only at `/home/blockexe/TrackerX/security-rotation-20260910.txt` with mode 600. Retrieve through key-authenticated SSH, distribute privately, and delete after all seven users complete password changes.